PENETRATION TESTING REPORT

FOOTPRINTING & NETWORK SCANNING PHASES

W2-PM-FINAL | CYBERSECURITY | NETWORKWALKS

Pentester Name (Cybersecurity Professional)	Chris Jeon
Program/Batch	[B084D]-Networkwalks
Date	11 November 2026
Modules completed	W2-PM1 (Multiple Kali Tools) W2-PM5 (Zenmap Scanning)
Client/Target	1. Networkwalks (secured written permission already) 2. My own local LAN Network
Permission secured from client?	Yes
Phases covered	**Phase 1:** Reconnaissance & Footprinting **Phase 2:** Scanning & Network Discovery **Phase 3-5:** In Progress

1. Liability Disclaimer

I have performed these activities only on the systems & devices where I had secured written permission or the devices/systems that I own myself. All these materials are for education and research purpose only. Do not use anything from here to break the law. The instructor, the authors and Networkwalks are not responsible for what you do with this knowledge. Every action you take is your own responsibility. Misuse can lead to criminal charges, heavy fines, loss of your job and a permanent record. In most countries unauthorised access is a crime even when nothing is damaged.

2. Introduction

This report covers footprinting the networkwalks.com domain using six Kali Linux tools (W2-PM1) and scanning my own home LAN with Zenmap (W2-PM5). The first module covers the footprinting phase and the second covers the scanning phase, so together they show how an attacker moves from gathering public information about an organisation to mapping the live hosts on a network. It is the Week 2 part of my ongoing internship program at Networkwalks.
The footprinting commands were run from a Kali Linux virtual machine on 10 November 2026. The network scan was run from my Windows 11 PC with Zenmap (Nmap 7.993) on the same day, together with the Windows ipconfig /all and arp -a commands. Each step below gives the command used and the result I observed; the matching screenshots are in Section 8, and Section 5 explains why each finding matters from an attacker's point of view.

3. Tools Used

The table below lists each tool used in this report and its purpose.

Tool	Purpose
Kali Linux & Windows 11	Operating systems used for the footprinting (Kali VM) and scanning (Windows PC) activities.
WHOIS	Find domain registration details (owner, dates, name servers).
whatweb	Fingerprint web technologies (server, CMS, plugins, IP).
nslookup	Resolve the domain name to its IP address using DNS.
curl -I	Read the HTTP response headers of the website.
wafw00f	Detect whether a Web Application Firewall protects the site.
dnsrecon	Enumerate all DNS records (NS, MX, SPF, TXT, SRV).
Zenmap (Nmap GUI)	Ping scan (nmap -sn) of the local subnet to find live hosts, IPs and MAC addresses, and draw the topology.
Windows CMD	ipconfig /all (local IP, subnet, gateway, own MAC) and arp -a (IP-to-MAC table of nearby hosts).

4. Activities Performed

4.1 Footprinting & Reconnaissance

I performed reconnaissance against the networkwalks.com domain using six Kali Linux tools: **WHOIS, WhatWeb, Nslookup, Curl, Wafw00f and DNSRecon**. Each tool collected a different type of information about the target.

First, I used **WHOIS** (whois networkwalks.com) to obtain the domain registration record. The domain is registered with **GoDaddy.com, LLC**, was created on **6 November 2019** and expires on **6 November 2027**. Registrant and technical contact details are hidden behind the privacy service **Domains By Proxy, LLC**, so no personal contact information was exposed. The record lists the name servers

NS6135.HOSTGATOR.COM and **NS6136.HOSTGATOR.COM** (the registrar record also lists NS29/NS30.DOMAINCONTROL.COM), shows that the domain is locked against unauthorised transfer, update and deletion, and states **DNSSEC: unsigned**.

I then used **WhatWeb** (whatweb networkwalks.com) to fingerprint the website. Plain HTTP returns a **301 redirect** to HTTPS. The site runs on an **Apache** web server at **192.232.216.135** and is built with **WordPress 7.1.4**, the **WordPress Download Manager 3.3.76** plugin, **jQuery 3.7.1**, Bootstrap and Google Tag Manager. WhatWeb also picked up the page title (Networkwalks Academy), the public contact email address and the __wpdm_client cookie, which is set with the HttpOnly flag.

Using **Nslookup** (nslookup networkwalks.com), I resolved the domain name through my router's DNS resolver (192.168.1.1). The non-authoritative answer returned the IP address **192.232.216.135**, matching the WhatWeb result.

I used **Curl** with the -I option (curl -I https://networkwalks.com) to read only the HTTP response headers. The server answered **HTTP/2 200** with server: Apache and x-nginx-cache: WordPress. The link header exposes the WordPress REST API endpoints /wp-json/ and /wp-json/wp/v2/pages/53, and the session cookie is set with the secure and HttpOnly flags. Common security headers such as **Strict-Transport-Security, Content-Security-Policy, X-Frame-Options and X-Content-Type-Options were not present** in this response.

Next, I used **Wafw00f** (wafw00f networkwalks.com) to check whether a Web Application Firewall protects the site. After two requests it reported that the site is behind **ModSecurity (SpiderLabs)**.

Finally, I used **DNSRecon** (dnsrecon -d networkwalks.com) for a standard DNS enumeration. It found 8 records: the SOA and name servers on HostGator (**ns6135.hostgator.com, 50.87.144.87** and **ns6136.hostgator.com, 192.232.216.131**), which both disclosed their DNS software version as **BIND 9.16.23-RH**; an **MX record (mail.networkwalks.com)** pointing to the same IP as the website, 192.232.216.135; a Google site-verification TXT record; an **SPF record** (v=spf1 +a +mx +ip4:50.87.144.87 +include:websitewelcome.com ~all); and eight _autodiscover._tcp SRV records pointing to cpanelemaildiscovery.cpanel.net, which shows the site uses cPanel hosting. The DNSSEC query returned no answer.

4.2 Network Scanning with Zenmap

For the second activity, I used **Zenmap** to perform network discovery on my own home network. The practical required me to identify my local IP address and subnet, discover live hosts, identify their IP and MAC addresses, and generate a network topology.

I first ran ipconfig /all in Windows Command Prompt. My PC's wired adapter has the IP address **192.168.1.154** with subnet mask **255.255.255.0**, so my LAN subnet is **192.168.1.0/24**. The default gateway, DHCP server and DNS server are all the router at **192.168.1.1**, and the adapter's physical (MAC) address is **70:85:C2:XX:XX:XX**. A second adapter, 192.168.56.1, is the VirtualBox host-only network used by my Kali VM, so I left it out of scope.

I then entered 192.168.1.0/24 as the target in Zenmap and selected the **Ping scan** profile (nmap -sn 192.168.1.0/24). The scan checked 256 addresses in 7.54 seconds and found **12 live hosts**:

- 192.168.1.1 – Router / default gateway (mynetworksettings.com) – MAC: 04:B3:C9:XX:XX:XX

- 192.168.1.3 – Tuya Smart IoT device – MAC: 00:33:7A:XX:XX:XX
- 192.168.1.5 – “desktop” (Intel) – MAC: F4:46:37:XX:XX:XX
- 192.168.1.6 – Personal device, hostname redacted (ASUSTek) – MAC: 10:7C:61:XX:XX:XX
- 192.168.1.7 – “thinkpad” (Intel) – MAC: DC:46:28:XX:XX:XX
- 192.168.1.9 – Unknown (randomised MAC) – MAC: 66:DF:FD:XX:XX:XX
- 192.168.1.10 – “PF4DJP34” (Intel) – MAC: 60:45:2E:XX:XX:XX
- 192.168.1.11 – Unknown (randomised MAC) – MAC: 46:69:BB:XX:XX:XX
- 192.168.1.20 – Raspberry Pi – MAC: B8:27:EB:XX:XX:XX
- 192.168.1.153 – Unidentified, no MAC reported – MAC: none
- 192.168.1.154 – My PC, the scanning host (from ipconfig) – MAC: 70:85:C2:XX:XX:XX
- 192.168.1.165 – Unknown (randomised MAC) – MAC: 96:7E:2C:XX:XX:XX

Nmap lists a MAC address for every host except two. **192.168.1.154** is my own PC (Nmap does not report the scanning machine’s own MAC), so I took its MAC from ipconfig /all. **192.168.1.153** also returned no MAC and no latency, which suggests it is a virtual interface on my PC rather than a separate device; arp -a had no entry for it, so this is not yet confirmed. Four hosts use randomised (locally administered) MAC addresses, which is typical of phones and tablets with MAC privacy turned on. I also noticed the number of live hosts changed between scans (11, 13, then 12) as devices joined and left the network, so all answers in this report use the single scan from 10 November 2026 at 23:38.

After completing the scan, I opened the **Topology** tab in Zenmap, enabled the legend and saved the network topology with **Save Graphic** in PDF format as required by the practical task. The map shows my PC (localhost) in the centre with all live hosts on one ring, which means every device is one hop away on a single flat network. All hosts appear as green circles because a ping scan does not check ports. The Topology view was blank at first and needed the window resized before it displayed. The saved map also shows 192.168.1.158, because Zenmap keeps hosts from earlier scans in the same session.

5. Risk Analysis / Impact

Based on the information collected during the footprinting and network scanning activities, I identified the following potential risks. Positive controls were also observed: WHOIS privacy protection, registrar locks on the domain, HTTPS redirection, Secure/HttpOnly cookie flags and an active WAF.

#	Risk / Finding	Evidence / Observation	Potential Impact	Risk Level
1	WordPress core and plugin versions exposed	WhatWeb: WordPress 7.1.4, WordPress Download Manager 3.3.76, jQuery 3.7.1	Exact versions let an attacker match the site against published vulnerabilities for WordPress and the plugin	● **Medium**
2	DNS server software version disclosed	DNSRecon: both name servers report BIND "9.16.23-RH"	A version banner helps target known BIND vulnerabilities; the upstream BIND 9.16 branch is end-of-life (vendor builds may include backported fixes)	● **Medium**
3	Home network: IoT and unidentified devices on one flat LAN	Zenmap: 12 live hosts incl. a Tuya smart device, a Raspberry Pi, 4 randomised MACs and 1 host with no MAC	IoT devices share a network with PCs, so one compromised device could reach the others; unknown hosts are hard to inventory	● **Medium**
4	HTTP security headers not observed	curl -I: no HSTS, CSP, X-Frame-Options or X-Content-Type-Options; "server: Apache" shown	Weaker browser-side protection against clickjacking, MIME sniffing and downgrade; the Server header helps fingerprinting	● **Low**
5	WordPress REST API endpoint exposed	curl -I Link header: /wp-json/ and /wp-json/wp/v2/pages/53	The REST API can be used to enumerate site content and, if not restricted, user accounts	● **Low**
6	Hosting and mail infrastructure identifiable	Nslookup/DNSRecon: website and MX both on 192.232.216.135; HostGator name servers; cPanel SRV records	Shows the hosting provider and control panel, and that web and mail run on the same server	● **Low**
7	DNSSEC not enabled	WHOIS: "DNSSEC: unsigned"; DNSRecon: no DNSSEC answer	DNS answers cannot be cryptographically validated, leaving room for spoofing or cache poisoning	● **Low**
8	WAF product identifiable	Wafw00f: ModSecurity (SpiderLabs)	Knowing the WAF helps an attacker choose bypass techniques, although having a WAF is itself a positive control	● **Low**

Risk level key: ● Critical ● Medium ● Low

The risks above are observations from the footprinting and scanning exercises, not confirmed vulnerabilities.

The practical exercises involved only information gathering and host discovery. No exploitation or vulnerability validation was performed as part of these two modules.

Therefore, the presence of information such as a software version, IP address or DNS record does not by itself mean that the system is vulnerable. Further authorized security testing would be required to confirm any actual vulnerability.

6. Recommendations

Based on the observations from these activities, I recommend the following security improvements:

1. **Hide version information**
   Remove the WordPress generator meta tag and plugin version strings so exact versions are not publicly visible.
2. **Keep WordPress core and plugins updated**
   Regularly update WordPress, WordPress Download Manager and other plugins, and check them against current security advisories.
3. **Add HTTP security headers**
   Configure Strict-Transport-Security, Content-Security-Policy, X-Frame-Options and X-Content-Type-Options, and reduce the detail in the Server header.
4. **Restrict the WordPress REST API**
   Limit unauthenticated access to sensitive REST endpoints such as /wp-json/wp/v2/users.
5. **Hide the DNS server version and keep BIND current**
   Ask the hosting provider to suppress the BIND version banner and confirm the DNS servers run a supported, patched release.
6. **Enable DNSSEC**
   Sign the zone with DNSSEC through the registrar and DNS host so DNS answers can be validated.
7. **Keep the WAF enabled and monitored**
   Keep ModSecurity enabled with an up-to-date rule set and review its logs, since it already blocks basic attacks.
8. **Separate IoT devices on the home network**
   Move smart-home devices such as the Tuya device onto a guest or IoT network, away from PCs, and keep the router firmware updated.
9. **Maintain a device inventory and investigate unknown hosts**
   Rescan the network periodically, identify the unknown hosts (including 192.168.1.153) and only scan networks where authorisation has been given.

7. Conclusion

During Week 2 of my Cybersecurity & Ethical Hacking internship, I completed practical activities covering footprinting, reconnaissance and network scanning.

In the footprinting activity, I used six Kali Linux tools against networkwalks.com. WHOIS showed the registrar, privacy-protected contacts and HostGator name servers; WhatWeb identified Apache, WordPress 7.1.4 and its plugins; Nslookup resolved the site to 192.232.216.135; Curl showed the

HTTP headers and the REST API endpoint; Wafw00f detected ModSecurity; and DNSRecon mapped the DNS, mail, SPF and SRV records and revealed the BIND version.

In the network scanning activity, I used ipconfig to find my IP (192.168.1.154) and subnet (192.168.1.0/24), then used Zenmap to discover 12 live hosts with their IP and MAC addresses and saved the network topology. I also learned why some hosts show no MAC address, how randomised MACs look, and how to cross-check results with arp -a.

The exercises showed me how much can be learned about an organisation and a network before any attack is attempted, using only public records and normal network responses.

I also learned that findings must be documented clearly and handled carefully: a good report explains what was performed, what was found, what it means and how to reduce the risk, and sensitive details such as MAC addresses and personal hostnames should be redacted before anything is shared publicly.

Finally, I learned that reconnaissance and scanning must always be performed within an authorized scope. These activities were completed as part of the assigned educational cybersecurity lab.

8. Evidences Collected

Figure 1 – whois networkwalks.com (registry record)



Figure 2 – whois networkwalks.com (registrar record)

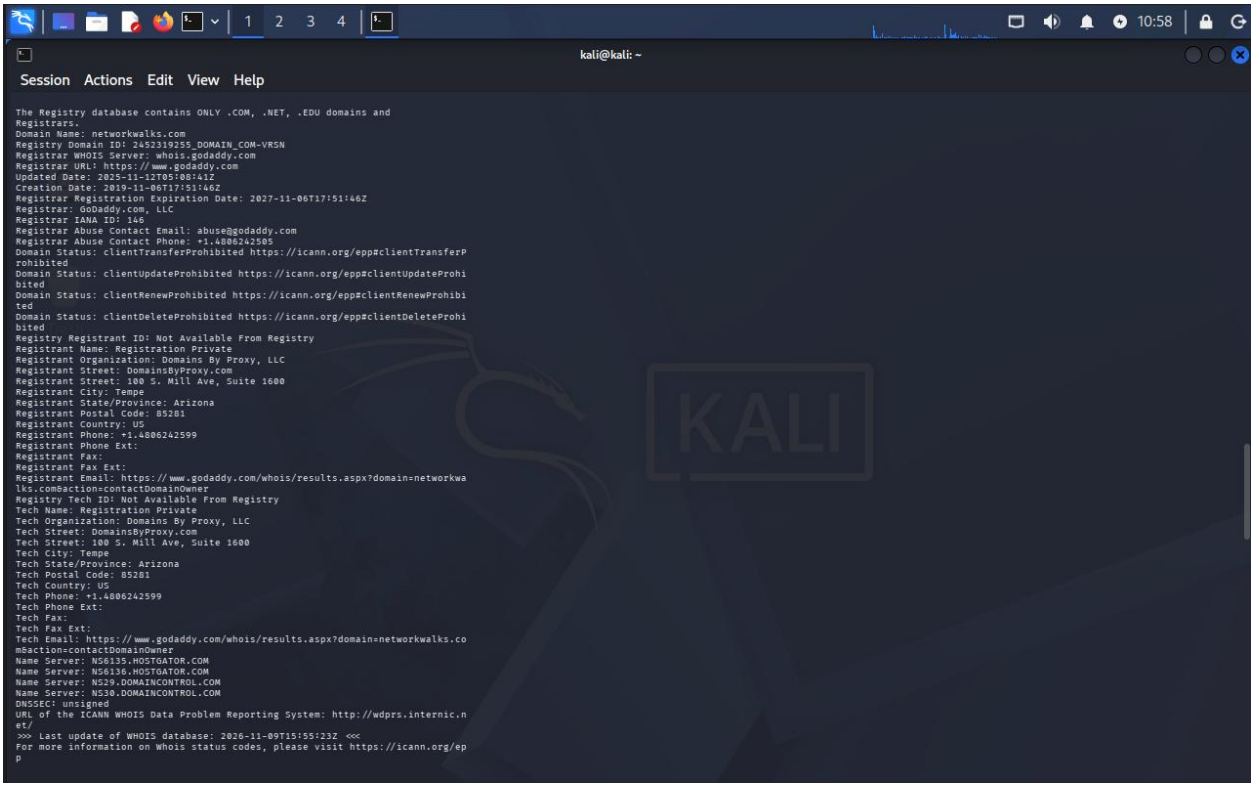


Figure 3 – whatweb networkwalks.com

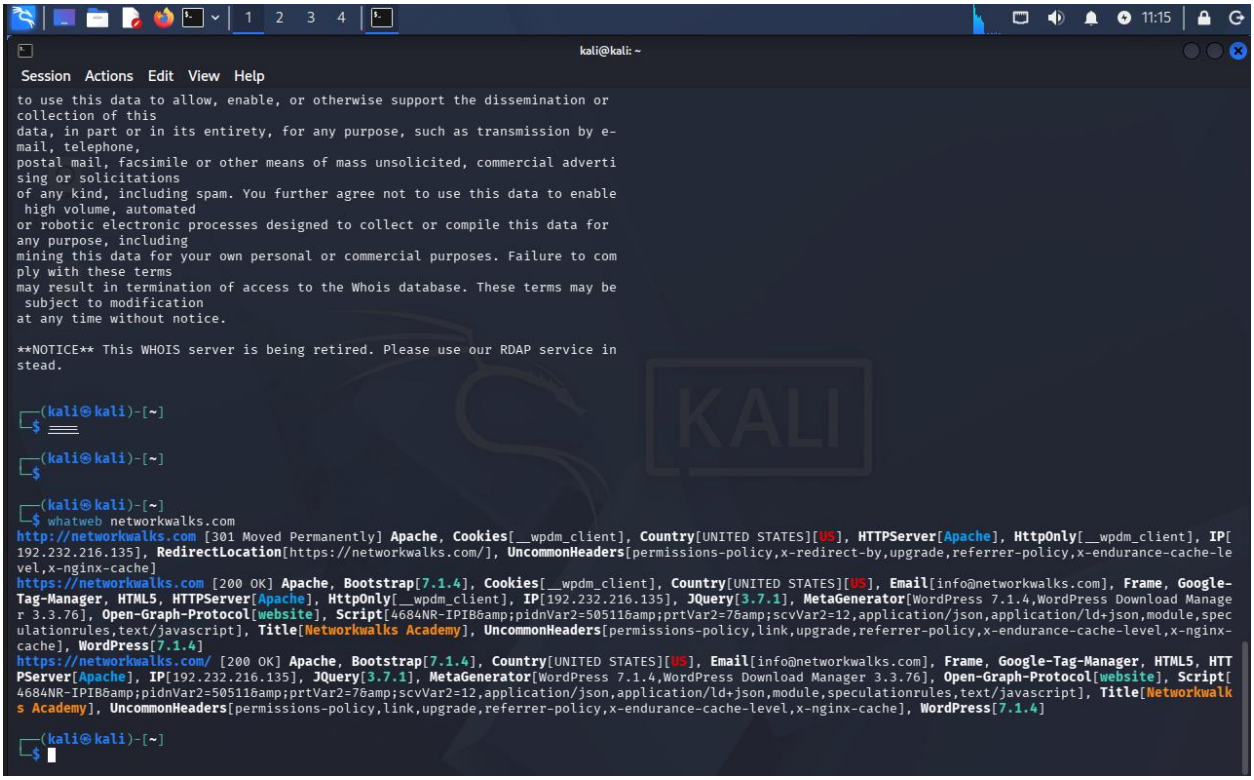


Figure 4 – nslookup networkwalks.com

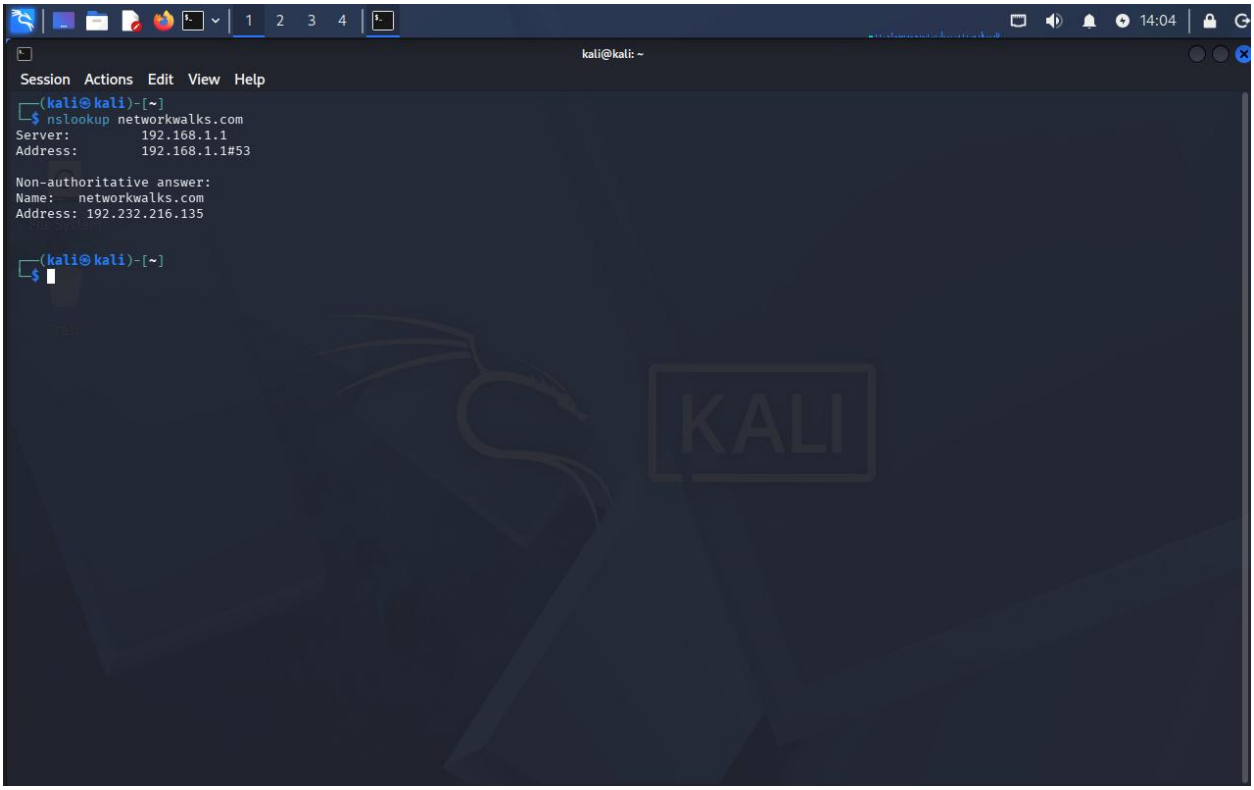


Figure 5 – curl -I https://networkwalks.com



Figure 6 – wafw00f networkwalks.com

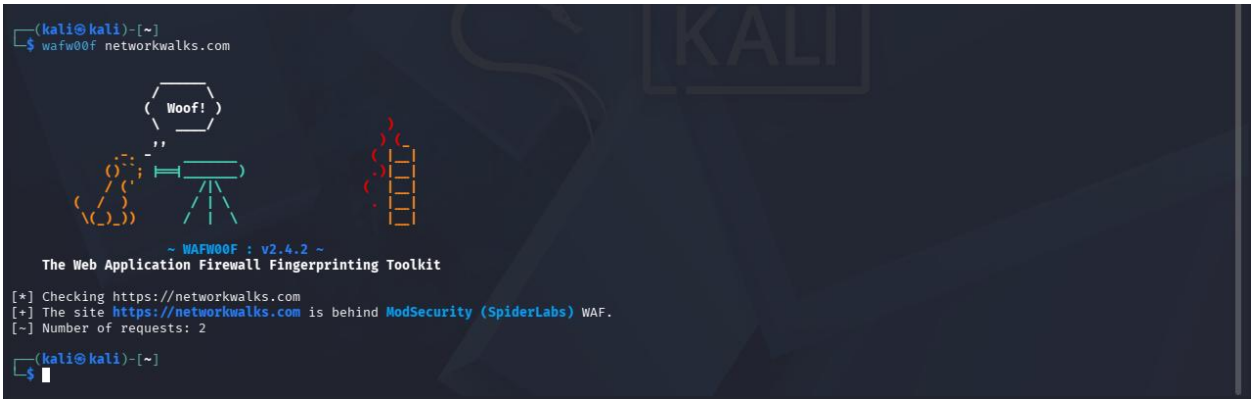


Figure 7 – dnsrecon -d networkwalks.com

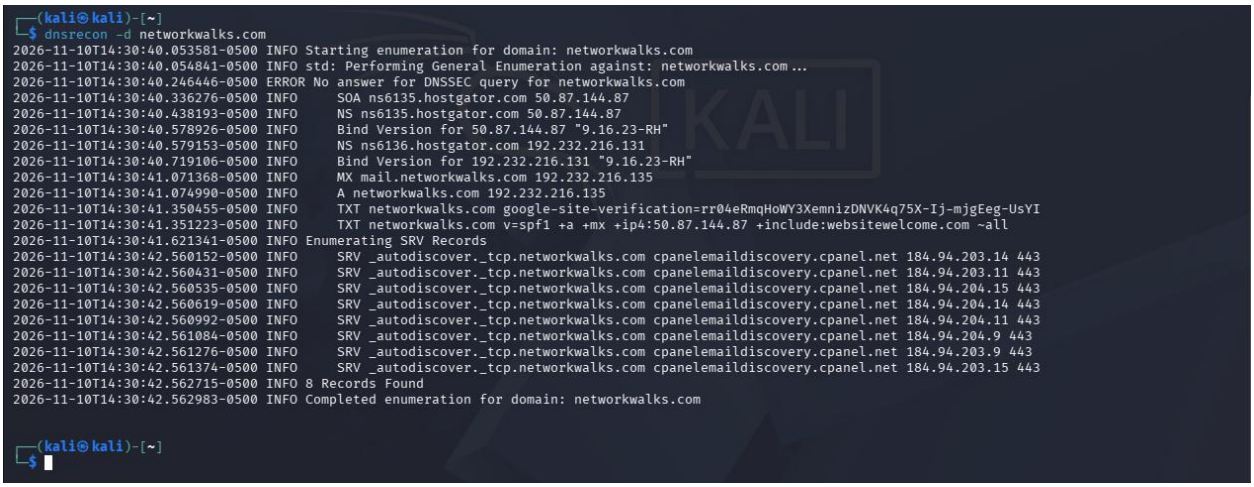


Figure 8 – ipconfig /all (local IP, subnet and MAC)

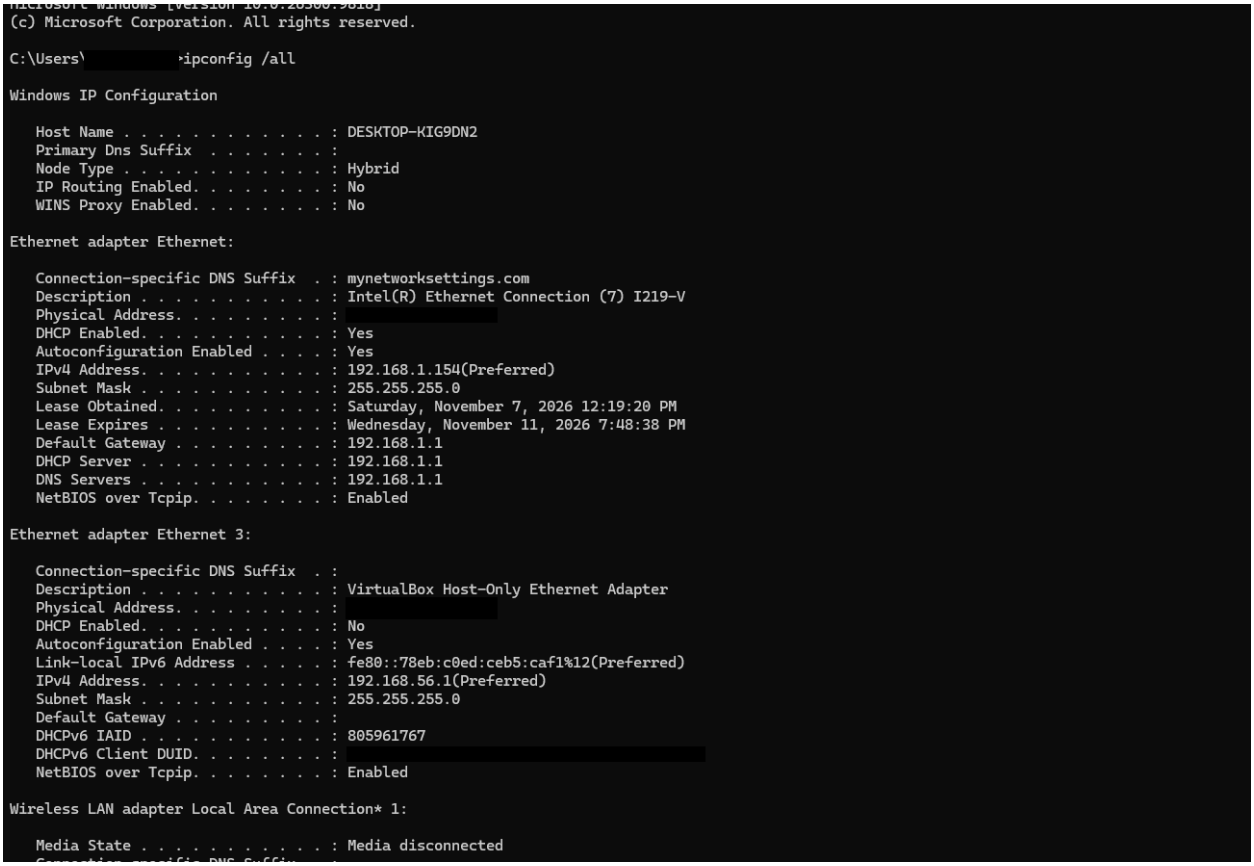


Figure 9 – Zenmap ping scan of 192.168.1.0/24 (12 hosts up)

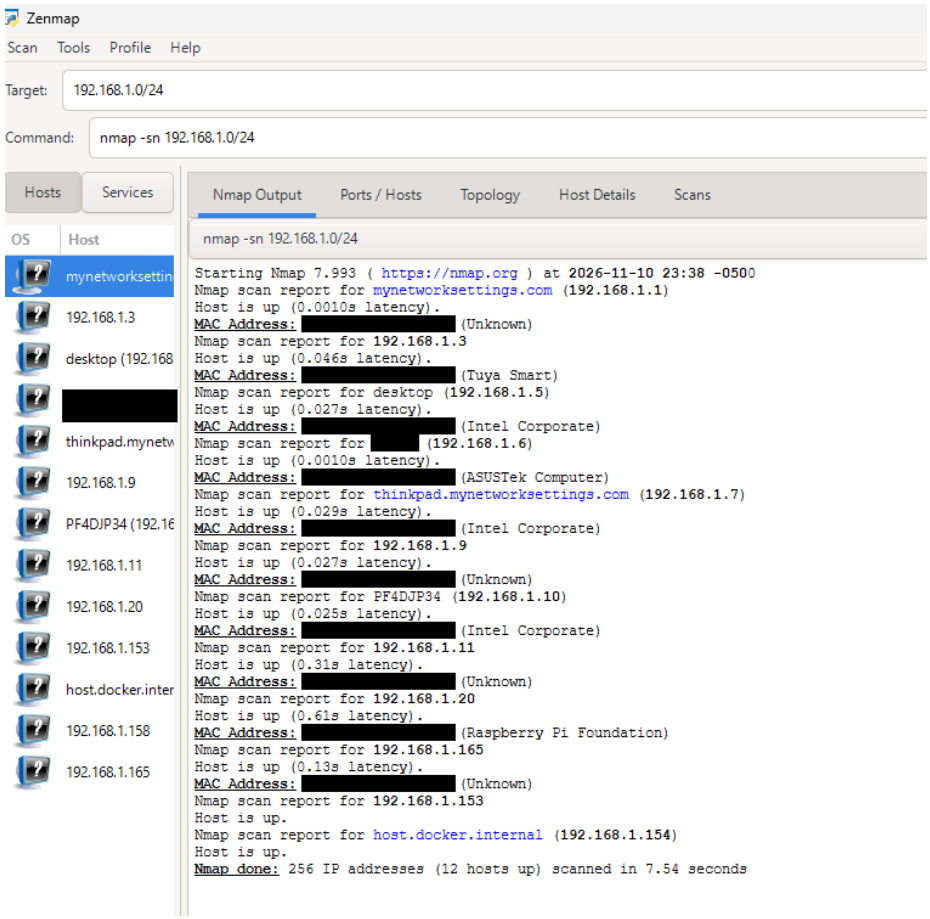


Figure 10 – arp -a (IP-to-MAC table)

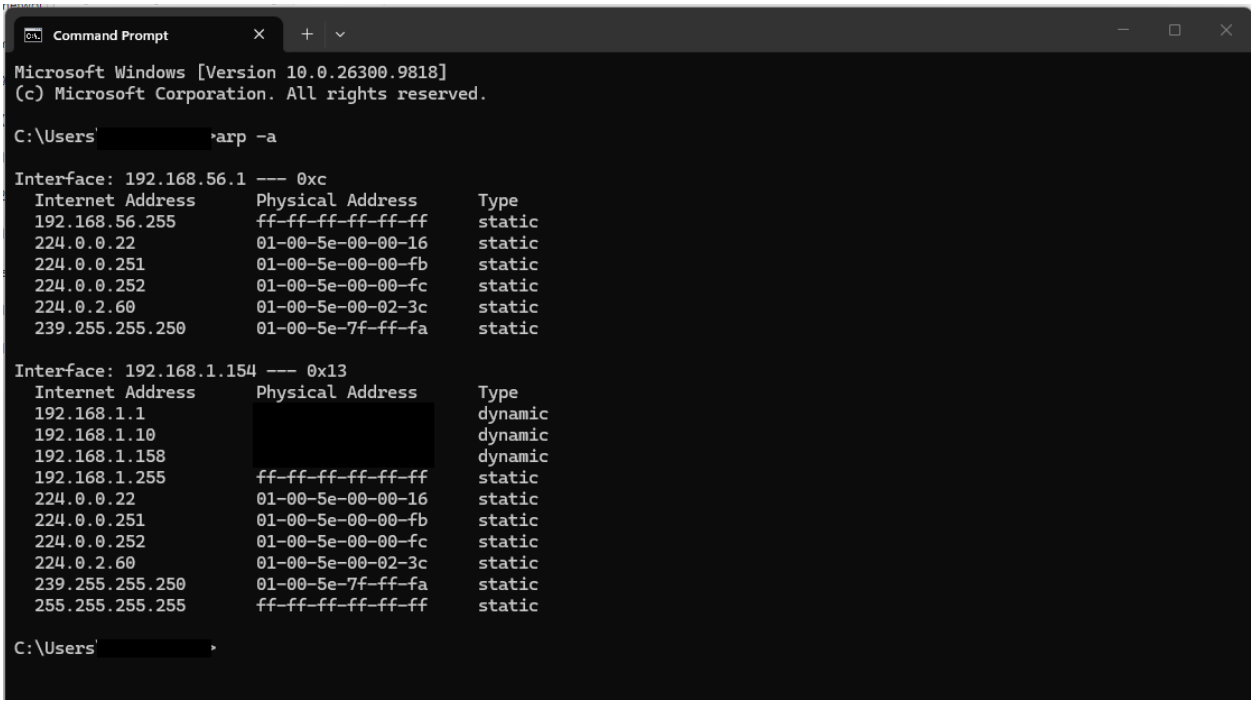
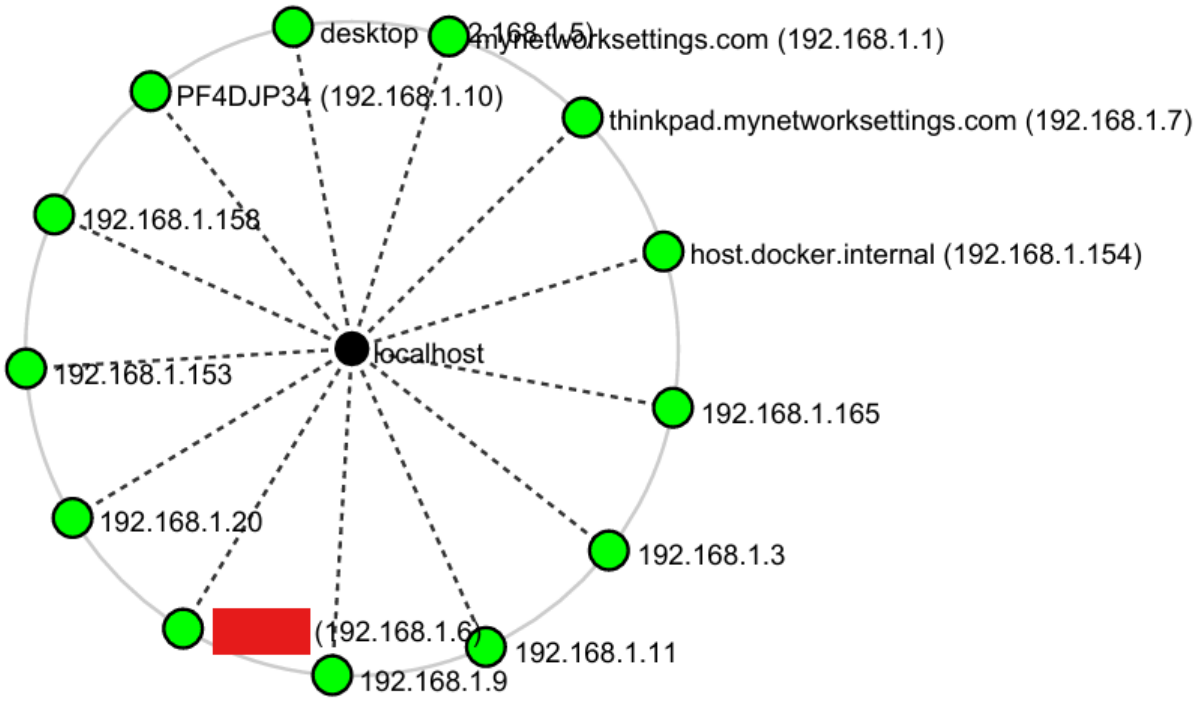


Figure 11 – Zenmap network topology (also shows 192.168.1.158 from an earlier scan in the same session)



-End-

Author
Chris Jeon
Cybersecurity Intern, Networkwalks

Project Information
Program Name: Cybersecurity program at Networkwalks | **Week:** 02 | **Repository:** GitHub